UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 5 slot(s). Supported theory: 17 slots. Placeholders: 2.
Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 13 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 5 computed, 17 supported by lecture slides, 2 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - computed - matches lecture slides 5-9 (Caesar shift 3 examples)

Question:

Using Caesar Cipher technique, decrypt the following ciphertext with a shift of 7 (replace each letter with the one 7 positions to the left).
KLCPJLYLABYULKHUKDPWLKVUL

Answer: DEVICERETURNEDANDWIPEDONE

Working:

```
K (10) -7 mod 26 -> D
L (11) -7 mod 26 -> E
C ( 2) -7 mod 26 -> V
P (15) -7 mod 26 -> I
J ( 9) -7 mod 26 -> C
L (11) -7 mod 26 -> E
Y (24) -7 mod 26 -> R
L (11) -7 mod 26 -> E
A ( 0) -7 mod 26 -> T
B ( 1) -7 mod 26 -> U
Y (24) -7 mod 26 -> R
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
H ( 7) -7 mod 26 -> A
U (20) -7 mod 26 -> N
K (10) -7 mod 26 -> D
D ( 3) -7 mod 26 -> W
P (15) -7 mod 26 -> I
W (22) -7 mod 26 -> P
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
V (21) -7 mod 26 -> O
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
```

Suggested marks: 1 mark for identifying the cipher/shift direction; 1 mark for the complete plaintext.
Confidence: computed - matches lecture slides 5-9 (Caesar shift 3 examples).

A1b - 6 marks - PLACEHOLDER

Topic: classical ciphers; command: State

Status: placeholder - no supported question passed verification.

Reason: A1b point 3: marking point is a verbatim copy of its quote; phrase the point as an answer requirement, not as copied slide text

PART A - QUESTION 2

© Hak Cipta Universiti Teknologi MARA

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a rail fence transposition cipher encrypts and decrypts a message.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Encryption writes the plaintext in a zigzag across rows and reads letters row by row to form the ciphertext.	"The plain-text is written in a zigzag pattern in rows and form the cipher-text by reading off the letters from the rows."	031 - Classical Cryptography, slide 25	031 - Classical Cryptography::s2 5::1	0.50	supported (ste gate)
2	Decryption rebuilds the empty rail fence table from the known key, fills rows with ciphertext, then reads in zigzag to recover plaintext.	"To decrypt a rail fence cipher, we have to recreate the 'empty' rail fence table (as in (A)) using the known key."	031 - Classical Cryptography, slide 26	031 - Classical Cryptography::s2 6::1	0.40 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 031 - Classical Cryptography, slide 25; 031 - Classical Cryptography, slide 26

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
  R (17) - E ( 4) = 13 -> N
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.
Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

Status: computed placeholder - no question generated for this type.

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six properties and cryptanalytic characteristics of classical cipher families, covering substitution, Vigenere, Caesar shift and columnar transposition.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

1	State that substitution ciphers work by replacing plaintext letters with other letters.	"In substitution ciphers, we replace the plain-text letters with other letters"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.71	supported (ste gate)
2	Identify the substitution rule as the key of the cipher.	"The substitution rule is the key"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.67	supported (ste gate)
3	Note that the Vigenere cipher resists straightforward frequency analysis.	"The Vigenere cipher is not amenable to simple frequency analysis"	031 - Classical Cryptography, slide 14	031 - Classical Cryptography::s14::1	0.57	supported (ste gate)
4	Explain that a keyword selects which encrypting rows are used in the Vigenere cipher.	"Use keyword to select encrypting rows"	031 - Classical Cryptography, slide 14	031 - Classical Cryptography::s14::1	0.67	supported (ste gate)
5	State that Caesar encryption shifts each letter three positions to the right in the alphabet.	"Replace each letter with the one three positions to the right in the alphabet."	031 - Classical Cryptography, slide 6	031 - Classical Cryptography::s06::1	0.57	supported (ste gate)
6	Describe that a double transposition performs a second transposition by sorting the keyword.	"Then we perform 2nd transposition by sorting the keyword to AHMT."	031 - Classical Cryptography, slide 24	031 - Classical Cryptography::s24::1	0.67	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 031 - Classical Cryptography, slide 14; 031 - Classical Cryptography, slide 24; 031 - Classical Cryptography, slide 4; 031 - Classical Cryptography, slide 6

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) formal security models and the specific security concern each addresses.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Bell-La Padula (BLP) model is a formal security model that deals with access control only.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.70	supported (ste gate)
2	The Chinese Wall model is a formal security model aimed at identifying conflicts of interest.	"Chinese Wall model: identification of conflicts of interest"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 5

Status: computed placeholder - no question generated for this type.

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how substitution ciphers hide messages and how the Arabs broke monoalphabetic substitution.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Encryption historically	"Historically, and also today,	031 - Classical	031 - Classical Cryptography::s0	0.56	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	(and today) involves substitution as a way of hiding the meaning of a message.	encryption involves Substitution"	Cryptography, slide 2	2::1		
2	The Arabs cryptanalysed monoalphabetic substitution by using frequency analysis, which easily reveals the letters ciphering E, T and A in English.	"The Arabs broke monoalphabetic substitution using frequency analysis"	031 - Classical Cryptography, slide 10	031 - Classical Cryptography::s10::1	0.46 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 031 - Classical Cryptography, slide 10; 031 - Classical Cryptography, slide 2

A5b - 6 marks - computed - 3 x 4 fill-rows/read-columns convention verified against lecture slides 20-21 and 24

Question:

Decrypt the following ciphertext using columnar transposition with a 4 x 6 matrix (4 rows, 6 columns). Put the ciphertext into the columns, read the plaintext out of the rows, and ignore the filler X at the end. The key is the keyword secret.
FOIENCXLRPYXOMTSEEEUCLRX

Answer: ENFORCECOMPLEXITYRULES

Working:

```
  Keyword: SECRET; read order: col 3 (C), col 2 (E), col 5 (E), col 4 (R), col 1 (S), col
6 (T)
  Grid: 6 columns x 4 rows (24 cells; ciphertext 24 chars; transport pad 0)
  Ciphertext split in read order:
    col 3 (C): FOIE
    col 2 (E): NCXL
    col 5 (E): RPYX
    col 4 (R): OMTS
    col 1 (S): EEEU
    col 6 (T): CLRX
  Reconstructed rows:
    row 1: ENFORC
    row 2: ECOMPL
    row 3: EXITYR
    row 4: ULESXX
  Row-wise: ENFORCECOMPLEXITYRULESXX
  Remove 2 trailing pad 'X': ENFORCECOMPLEXITYRULES
```

Suggested marks: 1 mark for the key column order; 2 marks for reconstructing the columns; 2 marks for the row-wise plaintext; 1 mark for stripping the padding.
Confidence: computed - 3 x 4 fill-rows/read-columns convention verified against lecture slides 20-21 and 24.

PART A - QUESTION 6

A6a - 2 marks - PLACEHOLDER

Topic: access control models; command: List
Status: placeholder - no supported question passed verification.
Reason: A6a: sub-angle not followed; use one of ['acl', 'acm', 'capability', 'access control list', 'matrix']

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

*Discuss the goals that authorization mechanisms pursue and the role of reference monitors, then explain how the Chinese Wall model's simple security rule and its *-property each address a specific security concern.*

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control aims to	"Goals of access control: Granting	023 - Access	023 - Access	0.50	supported (ste

© Hak Cipta Universiti Teknologi MARA

	grant access to permitted subjects.	access"	Control and Authorization, slide 4	Control and Authorization::s0 4::1		gate)
2	Access control also aims to limit and prevent access.	"Limiting access Preventing access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s0 4::1	0.50	supported (ste gate)
3	Reference monitors are the instruments used to realize access control policies and can be deployed at every level of the system hierarchy.	"Reference monitors are instruments for realization of access control policies."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s1 8::1	0.54	supported (ste gate)
4	The Chinese Wall simple security rule addresses conflicts of interest by only allowing access within the same company dataset already accessed or to an entirely different conflict class.	"is in the same company datasets as the objects already accessed by s, that is, "within the Wall," or belongs to an entirely different conflict of interest class."	024 - Formal Security Model, slide 25	024 - Formal Security Model::s25::1	0.61	supported (ste gate)
5	The Chinese Wall *-property addresses the concern of writing unsanitized information by permitting write access only when the simple security rule allows it and no readable object in a different company dataset contains unsanitized information.	"Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information."	024 - Formal Security Model, slide 26	024 - Formal Security Model::s26::1	0.62	supported (ste gate)
6	The Chinese Wall policy is specifically crafted to resolve conflicts of interest for consultants or contractors, showing that policies can target specialized problems.	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26; 024 - Formal Security Model, slide 27

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe the two stages of the biometric authentication process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The identification stage covers acquisition, creation of master characteristics and storage of master characteristics.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s0 5::1	0.86	supported (ste gate)
2	The authentication stage involves acquisition(s), comparison and a decision.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s0 5::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 072 - Biometrics and Authentication, slide 5

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six points about biometric mechanisms and technologies, covering their definition, categories, and specific technologies with their limitations.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A biometric is defined as a physiological or behavioural characteristic of a human that can distinguish one person from another and can theoretically be used for identification or verification.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.92	supported (ste gate)
2	Biometric applications are divided into two sectors: psychological and behavioural.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.57	supported (ste gate)
3	The psychological category includes iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.78	supported (ste gate)
4	The behavioural category includes voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
5	Iris scanning reads the unique pattern of the iris, is coloured and visible from a distance, and requires no touch, which overcomes issues of retinal scanners.	"Scans unique pattern of iris"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1	0.29 LOW	partly supporte
6	Fingerprint biometrics suffer from disadvantages such as racial issues, dirt, grime and wounds, finger placement problems, an excessively large database to process, and spoofing, making liveness detection important.	"Can be spoofed - liveness important!"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.14 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how the TPM anchors a chain of trust during platform boot.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

© Hak Cipta Universiti Teknologi MARA

1	The chain of trust is the central concept of the Trusted Computing architecture, where each stage measures and validates the next stage.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.36 LOW	partly supporte
2	The measurements produced by each stage are recorded in the Platform Configuration Registers (PCRs) held on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 8

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Explain six components and functions of the NGSCB/Nexus architecture that support trusted computing on a platform.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Nexus is described as a security kernel that is authenticated during boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.67	supported (ste gate)
2	Nexus authenticates trusted programs.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.75	supported (ste gate)
3	Nexus provides the application interface to the TPM.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.60	supported (ste gate)
4	Nexus does not trust the operating system.	"Does not trust OS"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.50	supported (ste gate)
5	The Nexus Computing Agent is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.40 LOW	supported
6	The NCA runs in trusted mode and communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two characteristics of Trojan horse malware that distinguish it from other malicious programs.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojans disguise themselves as useful or benign software so users install them willingly.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.00 LOW	supported
2	Once running, a Trojan steals private data, deletes files, records keystrokes, or opens a	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.64	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	backdoor for further malware.					

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Compare how a boot sector virus and a rootkit each achieve their malicious effect on an infected system, and explain why the rootkit is harder to detect.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A boot sector virus preserves the original master boot record elsewhere before replacing it with an infected version.	"Save the original MBR in a safe location"	051 - Software Security, slide 8	051 - Software Security::s08::1	0.08 LOW	supported
2	The boot sector virus then overwrites the master boot record with the infected copy so the system bootstraps using it.	"Overwrite the MBR with an infected one"	051 - Software Security, slide 8	051 - Software Security::s08::1	0.18 LOW	supported
3	A rootkit conceals malicious processes and software on the infected machine so that privileged remote access is maintained.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.73	supported (ste gate)
4	A rootkit is typically installed only after a vulnerability has been found and detected, keeping the computer under the author's control.	"They are usually installed after a vulnerability has been found and detected so that the infected computer continues to be under the control of the malware author."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.71	supported (ste gate)
5	Rootkit detection is difficult because rootkits are built to remain hidden from the very software used to detect them.	"Rootkit detection is quite difficult as they are designed to stay hidden from the very software used to detect them."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.70	supported (ste gate)
6	A rootkit is difficult to detect because it is designed to conceal itself from the very detection software used against it.	"Rootkit detection is quite difficult as they are designed to stay hidden from the very software used to detect them."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 13; 051 - Software Security, slide 8

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) impacts of malware attacks on the confidentiality, integrity or availability of information.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A malware attack can cause disclosure,	"Disclosure - unauthorized access to information"	011 - Introduction to	011 - Introduction to Computer	0.25 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	meaning information is accessed without authorisation, which harms confidentiality.		Computer Security, slide 10	Security::s10::1		
2	A malware attack can cause disruption, interrupting or preventing correct operation, which harms availability.	"Disruption - interruption or prevention of correct operation"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.46 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how the Samy worm used cross-site scripting to propagate itself and describe its eventual impact, giving six distinct points.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by writing to document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
2	It retrieved the list of the user's heroes by issuing a GET request on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.43 LOW	supported
3	It added Samy as a friend by performing XML-HTTP requests on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.78	supported (ste gate)
4	Any user visiting an infected user's page had their own profile and friends list infected with the JavaScript and with Samy.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.73	supported (ste gate)
5	The infection ultimately spread to about 1,000,000 MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.57	supported (ste gate)
6	The underlying weakness is that any web application returning user input without filtering is a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.77	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss how morals, ethics and laws differ as guides for behaviour, and explain how the ACM code of ethics and professional conduct should shape a computing professional's actions.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Explain that morals are	"Morals are traditions of belief	071 - Ethics and	071 - Ethics and	0.82	supported (ste

© Hak Cipta Universiti Teknologi MARA

	traditions of belief about right and wrong conduct, forming the bedrock of social behaviour.	about right and wrong conduct and "doing what is morally right" is the bedrock of our social behavior"	Computer Security, slide 5	Computer Security::s05::1		gate)
2	State that ethics is a suite of guiding beliefs, standards or ideals that pervades an individual or a group or community.	"Ethics is a suite of guiding beliefs, standards, or ideals that pervades an individual or a group or community of people"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)
3	Describe laws as formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)
4	Note that ethics is a documented set of acceptable behaviours for professional or social groups, defined by the group, identifying specific actions as appropriate or inappropriate.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.46 LOW	partly supporte
5	Explain that under the ACM code a computing professional should contribute to society and human well-being, avoid harm, be honest and trustworthy, be fair and not discriminate, respect privacy and honour confidentiality.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.24 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 5; 071 - Ethics and Computer Security, slide 6

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain five ways the ACM code of ethics and professional conduct should guide the software engineer's actions in this situation.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The engineer should aim for high quality in the processes and products of the professional work, resisting pressure to release an unfinished product.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.46 LOW	partly supporte
2	The engineer should uphold high standards of professional competence, conduct and ethical practice while handling the release decision.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.50	supported (ste gate)
3	The engineer should give a comprehensive and thorough evaluation of the system and its impacts,	"Give comprehensive and thorough evaluations of computer systems and their impacts, including analysis of possible risks."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.67	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	including possible risks, before release.					
4	The engineer should design and implement the patient-monitoring system so that it is robustly and usably secure.	"Design and implement systems that are robustly and usably secure."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.60	supported (ste gate)
5	The engineer should protect patients' personal information, since privacy means protecting one's personal information.	"Protecting one's personal information"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.33 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 12; 071 - Ethics and Computer Security, slide 13

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State FIVE (5) points about software insecurity and buffer overflows, covering their causes, how a stack buffer overflow hijacks execution, and techniques used to strengthen software security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Software insecurity arises because an attacker can modify system resources that are critical for program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.72	supported (ste gate)
2	A key source of software insecurity is the failure to validate user input.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.86	supported (ste gate)
3	Buffer overflows are among the most widely used exploitation techniques.	"Buffer overflows are a most widely used exploitation technique."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.71	supported (ste gate)
4	Without proper bound checking, a local buffer can overspill into the adjacent upper stack area.	"Without proper bound checking a buffer content can overspill into adjacent upper stack area."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.92	supported (ste gate)
5	By controlling the buffer content, an attacker can overwrite the return address with an arbitrary value and thereby hijack the execution flow.	"By controlling buffer content, an attacker can overwrite the return address with an arbitrary value and hijack the execution flow."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 30

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain FIVE (5) points about the Windows security mechanisms, covering the directory service used to

© Hak Cipta Universiti Teknologi MARA

organise resources, the registry hives holding security data, how access rights are encoded, and why the complexity of these mechanisms can itself be a weakness.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Active Directory, introduced in Windows 2000, is an LDAP-like directory service used to organise system resources such as users, groups, credentials, policies and trust.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.59	supported (ste gate)
2	The registry is a hierarchical database of critical system information, and specific hives such as SAM and Security hold security-related data like the SAM database and security logs.	"A hierarchical database containing critical system information"	041 - Windows Security, slide 4	041 - Windows Security::s04::1	0.33 LOW	partly supporte
3	Access rights describe what a subject can do to an object and are encoded as a 32-bit mask, with standard rights such as DELETE, READ_CONTROL and WRITE_DAC common to most object types.	"Encoded as a 32-bit mask"	041 - Windows Security, slide 16	041 - Windows Security::s16::1	0.18 LOW	partly supporte
4	Windows contains complex mechanisms for user account and object management and access control, and DACs allow fine-grained access control of heterogeneous entities in Windows and its applications.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.59	supported (ste gate)
5	The complexity of Windows security mechanisms is also its enemy, because misconfiguration and implementation bugs may lead to severe security incidents.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 041 - Windows Security, slide 16; 041 - Windows Security, slide 21; 041 - Windows Security, slide 4; 041 - Windows Security, slide 6

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA